

Navigateur · Chaîne de confiance

Extensions de navigateur : quand la confiance change de mains

Notre plateforme s'exécute entièrement dans le navigateur, et mes tests aussi. Une extension installée depuis des mois peut devenir malveillante du jour au lendemain — et, accessoirement, fausser un rapport d'anomalie.

Date de veille 15 juillet 2026**Rédacteur** Sami El Abdallaoui, stagiaire veille et contenus**Déclencheur** Le navigateur est à la fois notre plateforme d'exécution et mon outil de test**Public visé** Équipe technique et pédagogique OpenCyberAI**Temps de lecture** 5 minutes

À retenir

- Le modèle de menace n'est pas l'installation, c'est le **temps**. Une extension légitime peut devenir hostile par rachat du projet, compromission du compte développeur, ou simple mise à jour.
- L'utilisateur n'est pas notifié d'un changement de propriétaire, et les mises à jour s'appliquent silencieusement depuis le canal officiel du magasin.
- Microsoft a documenté en mars 2026 des extensions Chromium présentées comme assistants IA, qui collectaient l'historique d'URL et le contenu de conversations : environ 900 000 installations, activité observée dans plus de 20 000 environnements d'entreprise.
- Le signal le plus simple à enseigner est la **disproportion** : un convertisseur de PDF qui réclame l'accès à tous les sites, à l'historique et aux onglets.
- En contexte sensible, la mise à jour doit redevenir un événement contrôlé : liste d'extensions approuvées, versions figées.

Le point de bascule n'est pas celui qu'on croit

L'image répandue est celle d'un attaquant qui publie une extension piégée en espérant des installations. C'est le cas le moins efficace. Le scénario rentable est l'inverse : prendre le contrôle d'une extension qui a déjà des dizaines ou des centaines de milliers d'utilisateurs.

Deux chemins mènent au même résultat. Le rachat, d'abord : un développeur indépendant qui ne veut plus maintenir son projet le cède, et rien n'oblige à prévenir les utilisateurs. La compromission de compte, ensuite : l'attaquant récupère les accès du développeur au magasin et publie une mise à jour depuis le canal légitime.

Dans les deux cas, l'extension conserve son nom, ses avis, son ancienneté et sa réputation. Rien ne change visuellement. Ce qui a changé, c'est qui détient les clés de signature et le droit de publier.

Les permissions sont le vrai périmètre

Une extension qui dispose de l'accès à tous les sites peut lire et modifier le contenu de n'importe quelle page consultée : formulaires, sessions ouvertes, contenus affichés. Ce n'est pas une capacité théorique, c'est le fonctionnement normal du modèle d'extensions.

D'où une règle simple, qui vaut aussi bien pour un professionnel que pour un élève de terminale : comparer les permissions demandées à l'utilité annoncée. Un bloqueur de publicité a besoin de droits étendus. Un outil qui change la couleur d'une page n'en a pas besoin. La disproportion n'est pas une preuve de malveillance, c'est un risque structurel — plus les droits sont larges, plus la compromission ultérieure est rentable.

Une conséquence directe pour une plateforme qui vit dans le navigateur

Nos contenus s'exécutent entièrement dans le navigateur de l'apprenant, et nous n'avons aucune maîtrise de cet environnement. Une extension capable d'injecter du script ou du style dans une page peut modifier le comportement d'un exercice — bloquer une validation, masquer un élément, altérer un affichage.

Deux conséquences pratiques. D'une part, un comportement anormal signalé par un utilisateur n'est pas nécessairement un défaut du produit : il peut venir de son poste. D'autre part, toute vérification sérieuse devrait se faire dans un environnement de référence sans extension — un profil dédié, ou la navigation privée, où elles sont désactivées par défaut.

C'est une distinction que je n'avais pas en tête avant cette veille, et qui me paraît maintenant élémentaire : sans connaître l'environnement, on ne peut pas savoir ce qu'on observe.

Bonnes pratiques applicables

- Faire l'inventaire des extensions installées et désinstaller tout ce qui n'a pas servi depuis des mois. Chaque extension conservée est une surface entretenue.
- Vérifier les permissions accordées, pas seulement au moment de l'installation mais après chaque mise à jour majeure.
- Se méfier d'un changement de mainteneur, d'une reprise d'activité soudaine sur un projet abandonné, ou d'un ajout de permissions justifié par une nouvelle fonctionnalité anodine.
- En environnement professionnel : liste blanche d'extensions approuvées et versions épinglées, plutôt que confiance accordée au magasin.
- Pour le test logiciel : profil de navigateur dédié, sans extension, ou navigation privée systématique.

Ce que cela change pour nos contenus

- Nos jeux traitent des protocoles, du chiffrement et du code, mais jamais du navigateur — alors que c'est l'outil que nos élèves utilisent toute la journée et la surface d'attaque la plus proche d'eux.
- Proposition d'un module court : lire les permissions d'une extension, repérer une disproportion, comprendre pourquoi une mise à jour automatique est un transfert de confiance.
- Le mécanisme du rachat est un excellent support narratif : il n'y a pas de « méchant hacker » au départ, seulement un développeur fatigué qui vend son projet. C'est plus juste, et plus marquant.
- À intégrer aussi dans notre documentation de test : préciser que l'environnement de référence est un navigateur sans extension.

Sources consultées

- Microsoft — analyse d'extensions Chromium de type assistant IA collectant historique et conversations, mars 2026
- GitLab Threat Intelligence — campagne d'extensions Chrome compromises par mises à jour malveillantes
- Documentation Chrome — modèle de permissions des extensions et politique de mise à jour
- Analyses publiées sur le risque de transfert de confiance lors du rachat d'une extension, 2026

Réserve : les volumétries d'installations affectées varient d'un rapport à l'autre selon la période et le périmètre retenus. Le mécanisme — mise à jour silencieuse après changement de contrôle — est en revanche constant et vérifiable dans la documentation officielle du modèle d'extensions.